

VERITRUST

IMPLEMENTATION HANDBOOK | 11 AUGUST 2026

Link Detection Architecture Blueprint

A complete evidence-first implementation plan for URL parsing, intelligence, models, isolation, training, scaling and safe production release.

- Repository-grounded findings and exact remediation order
- Hugging Face candidate models with strict label contracts
- SSRF-resistant enrichment and isolated browser architecture
- Interactive model worksheet and release checklist

Status: implementation-ready design; models and connectors remain qualification-gated

Scope: URL/link evidence only; the Unified Gateway remains final decision authority



How to use this handbook

This is a build specification, not a safety guarantee

No link detector can establish that an unseen destination is safe. This design separates observed evidence, missing evidence, calibrated probability and Gateway policy. Work through D0-D8 in order and do not enable hostile URL dereferencing before the isolation gates pass.

Decision that must be made first

Freeze the exact server-configured Swift repository, commit, task, tokenizer, input normalization and label map. The identifier is hidden behind `HF_LINK_SWIFT_MODEL`; repository code alone cannot prove which model is deployed.

Document conventions

Marker	Meaning
REQUIRED	Must pass before the capability can affect production policy.
CANDIDATE	Shortlisted component; not approved until local security, license and benchmark gates pass.
INITIAL	A versioned starting limit or hyperparameter; tune using measured operating data.
SHADOW	Runs without affecting user-facing decisions.

Recommended reading order

- Engineering leads: Sections 1-5, 8-16 and 19.
- ML engineers: Sections 7-8 and 16-18.
- Security/platform engineers: Sections 9-12 and 20-23.
- Product/operations: Sections 13-15, 19 and 22-25.

Table of contents

How to use this handbook	2
Decision that must be made first	2
Document conventions	2
Recommended reading order	2
Table of contents	3
1. Executive implementation decision	6
Release blockers found in the repository	6
What to build	6
2. Scope, terms and trust boundary	6
In scope	6
Explicitly deferred	6
Vocabulary	7
3. Repository-grounded current architecture	7
Current implementation map	8
Verified edge cases	8
What is useful and should be preserved	8
4. Target Link Detection architecture	9
Tiered execution	10
5. URL identity and normalization specification	10
Five representations - never one overloaded string	10
Required parser order	10
Canonicalization rules	10
Initial input limits	11
6. Static evidence and feature contract	11
Feature families	11
Evidence, not a score shortcut	11
7. Hugging Face model portfolio and selection	12
Recommended portfolio	12
Model-selection recommendation	12
8. Model parameter cards and registry	12
URLBERT four-class inference card	12
Feature GBDT inference card	13
Registry fields - required before a model call	13
9. Live intelligence and enrichment architecture	13
Connector portfolio	13
Connector evidence envelope	14
Freshness and caching	14

10. SSRF-resistant dereference boundary	14
Mandatory controls	14
Initial network budgets	15
11. Redirect, DNS and registration evidence	15
Redirect artifact graph	15
DNS evidence	15
RDAP and TLS evidence	15
12. Browser sandbox specification	16
Isolation profile	16
Browser evidence taxonomy	16
13. Evidence states, sufficiency and abstention	16
Link evidence verdicts	17
Sufficiency profiles	17
14. Scoring, calibration and policy boundary	17
Data fields that must remain separate	17
Calibration workflow	17
Current scoring migration	17
15. Canonical data and API contracts	18
LinkArtifact example	18
LinkEvidence example	18
Recommended endpoints	18
Error taxonomy	18
16. Data acquisition and label governance	19
Source portfolio	19
Label schema	19
Leakage controls	19
17. Training and fine-tuning recipes	19
Recipe A - URLBERT four-class	19
Recipe B - independent static feature GBDT	20
Recipe C - sandbox page-text model	20
Recipe D - optional visual brand evidence	20
18. Benchmark, robustness and calibration package	20
Required metrics	20
Mandatory slices	20
Adversarial transformations	21
Promotion gates	21
19. Exact implementation roadmap	21
First engineering tickets	22

20. Test architecture	22
Golden parser corpus	22
21. Deployment, scaling and backpressure	23
Recommended topology	23
Service targets - initial, not promises	23
Backpressure rules	23
22. Observability, drift and feedback	23
Metrics	23
Drift policy	23
Trace context	24
23. Security, privacy, licensing and release governance	24
Security controls	24
Licensing and data gate	24
Definition of done	24
24. Interactive operator worksheet	24
Current Swift deployment	24
Target operating context	25
Connector and sandbox approvals	25
25. Interactive implementation and release checklist	26
Truth and parser	26
26. Sources and primary references	27

1. Executive implementation decision

VeriTrust should become a tiered URL evidence system, not a single blended score. Every URL receives deterministic parsing and static analysis. Policy-selected requests add reputation, network metadata and browser evidence asynchronously. Each observation remains independent and versioned.

Release blockers found in the repository

Priority	Finding	Required correction
P0	The provider label map is hard-coded and guessed for generic LABEL_n outputs.	Resolve the exact model before inference; reject unknown or duplicate labels.
P0	Provider failure can return ok=true through a local heuristic fallback.	Return DEGRADED/FAILED evidence; never manufacture model scores or a safe result.
P0	The registered-domain helper takes the last two labels.	Use a pinned Public Suffix List implementation and persist its version.
P0	decodeURIComponent is called on URLSearchParams values and can throw URIError.	Use a total parser; never recursively or unsafely decode query values.
P1	No reputation, DNS, RDAP, TLS, redirect, HTTP or browser evidence exists.	Add isolated asynchronous enrichment with explicit freshness and failure states.
P1	Arbitrary rule weights and raw model scores are labeled confidence/risk.	Calibrate model outputs; preserve raw score, probability, sufficiency and risk separately.
P1	Gateway model registry is resolved after inference.	Resolve the exact active revision and contract before preprocessing or provider calls.
P2	Web, developer API, platform worker and Gateway differ on fallback behavior.	Use one capability registry and one LinkEvidenceAdapter across every entry path.

Potentially critical model mismatch

If Swift points to CrabInHoney/urlbert-tiny-v4-malicious-url-classifier, its model card maps LABEL_1 to defacement and LABEL_3 to phishing. Current VeriTrust code maps LABEL_1 to phishing and LABEL_3 to defacement. Do not assume that this is the deployed model; record its exact identity and then test the declared mapping with golden fixtures.

What to build

- A single LinkEvidenceAdapter consumed by web, v1 API, Gateway and workers.
- A total, PSL-aware URL identity module that preserves raw and comparison forms.
- Independent static, model, reputation, network and browser evidence families.
- An async enrichment plane isolated from application secrets and internal networks.
- An abstaining evidence contract; only Gateway policy may ALLOW, REVIEW, HOLD or BLOCK.

2. Scope, terms and trust boundary

In scope

- HTTP and HTTPS URLs submitted directly or derived from another artifact.
- Parsing, canonical identity, IDN/confusable analysis and PSL-aware registered domains.
- Static lexical/structural features, URL models, reputation and live metadata.
- Constrained browser evidence: forms, navigation, requests, scripts and screenshots.
- Calibration, abstention, data governance, deployment and operational controls.

Explicitly deferred

- Automatic takedown, active exploitation, credential submission, CAPTCHA bypass and malware execution.
- QR/quishing decoding, attachment detonation and long-lived campaign memory.
- A final trust action inside the Link Engine; this remains Gateway policy authority.

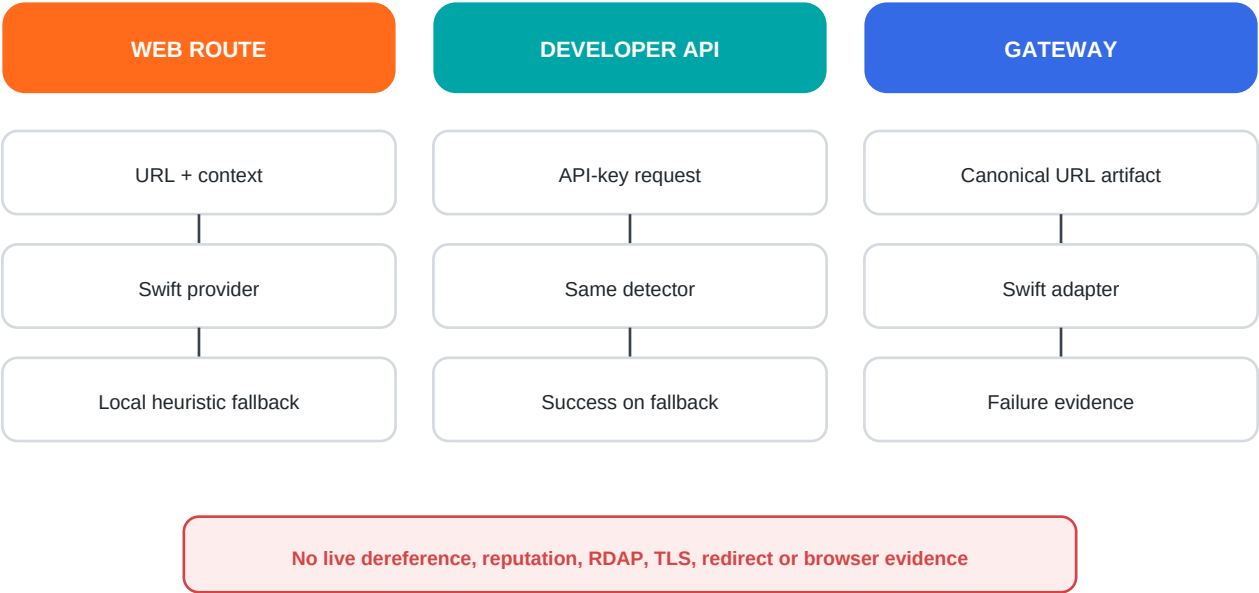
Vocabulary

Term	Precise meaning
Raw URL	The submitted text after bounded transport decoding; retained or HMACed per policy.
Parsed URL	Scheme, userinfo, host, port, path, query and fragment produced by a total parser.
Registered domain	PSL-aware eTLD+1; not the final two hostname labels.
Canonical comparison URL	A versioned representation for deduplication/features; never assumed equivalent for every provider.
Dereference	Any DNS resolution, HTTP connection or browser navigation to the destination.
No match	A connector has no listed threat. It is not evidence that the URL is benign.
Evidence freshness	Observed-at time plus provider/collector TTL and dataset version.

Trust boundary

The API process may parse and enqueue. Only a least-privilege enrichment worker may resolve or connect to user-supplied destinations. The browser stage must be a further isolated workload with no access to Supabase service credentials, model-build credentials or internal administrative endpoints.

3. Repository-grounded current architecture



The direct web route and developer API call runLinkDetection with local fallback enabled by default. The Gateway adapter disables that fallback and persists a failed evidence object. The optional platform worker uses the permissive default. These are materially different semantics for the same product capability.

Current implementation map

Layer	Current file	Observed behavior
Core URL logic	lib/link-intelligence.js	URL parsing, string heuristics, fixed scoring, label normalization and result construction.
Provider orchestration	lib/detection-service.js	Calls Hugging Face, optionally creates local fallback model scores, finalizes legacy result.
Gateway adapter	lib/models/malicious-url.js	Converts legacy result into Gateway evidence; provider fallback disabled.
Web route	lib/routes/detection/link-check.js	Authenticated browser scan lifecycle and legacy result.
Developer API	lib/routes/v1/link-check.js	API-key route; same permissive fallback default.
Gateway	lib/gateway/contracts.js / extractor.js / router.js	Stricter canonicalization, URL artifacts and fast Swift route.
Persistence	lib/gateway/persistence.js	Looks up a model version only after the model has already run.
UI	assets/js/pages/link-check.js	Displays model confidence as meter width and a final Safe/Suspicious/Phishing/Malicious label.

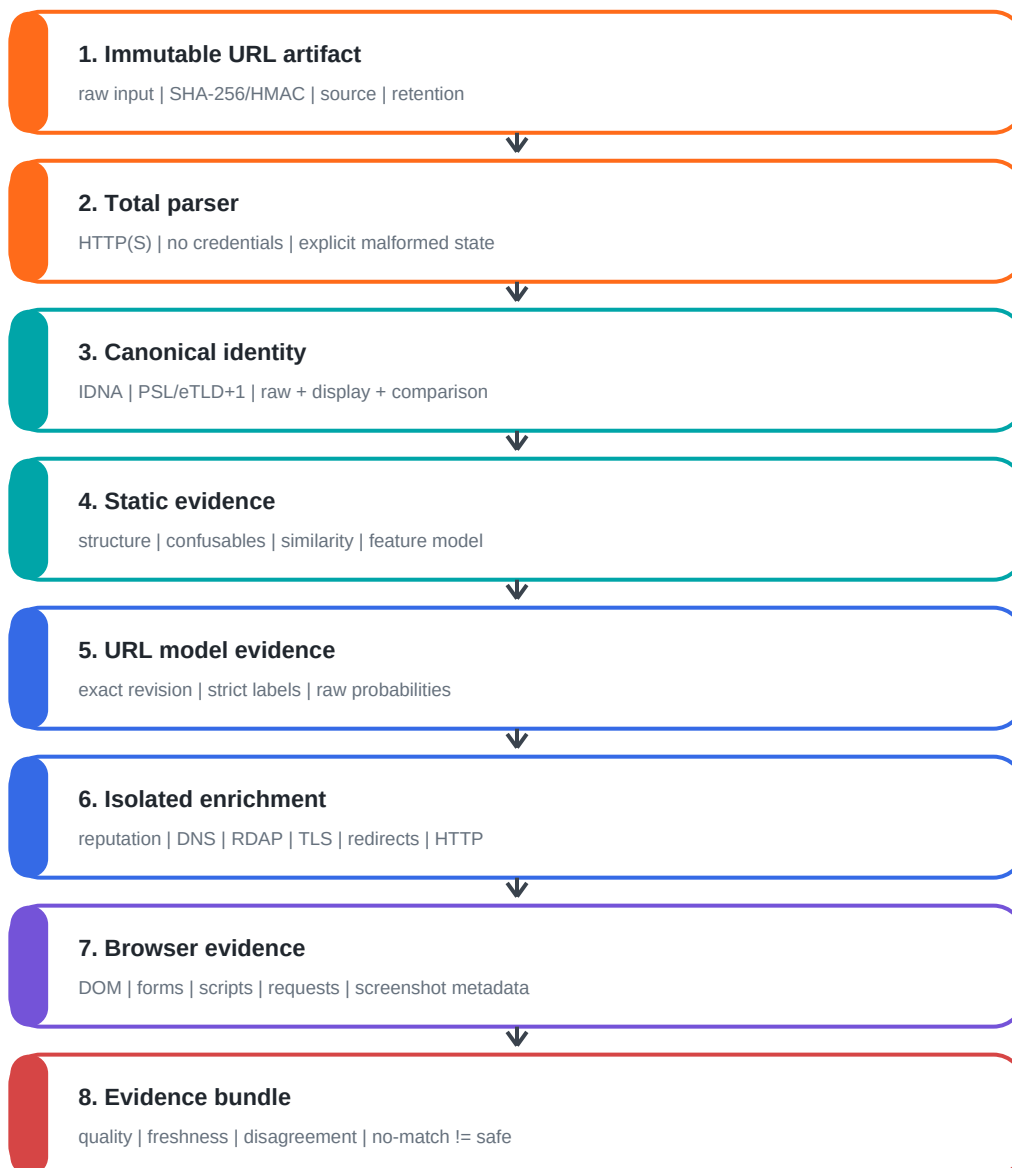
Verified edge cases

Input	Current observation	Required behavior
https://example.co.uk/login	registered domain becomes co.uk	registered domain must be example.co.uk
https://example.com/?next=%25	URIError: URI malformed	parse successfully; detect safely without recursive decode
https://user:pass@example.com/	accepted by direct detector	reject credentials consistently
xn-- IDN host	generic punycode indicator only	retain A-label/U-label plus UTS #39 script/confusable evidence

What is useful and should be preserved

- HTTP(S) scheme restriction, bounded request bodies and deduplication scaffolding.
- Reason-like indicators and an existing Gateway Evidence adapter boundary.
- Tenant HMACs, URL artifacts, idempotency and durable Gateway persistence concepts.
- Explicit disclosure in model-performance UI that live enrichment is not yet present.

4. Target Link Detection architecture



Core invariant

A connector outage, model failure, unsupported URL, missing browser run or reputation no-match can never become a low-risk observation. Evidence sources report exactly what they observed and how fresh/reliable it is.

Tiered execution



Fast response returns durable partial evidence; later tiers update the investigation

A skipped or failed tier is missing evidence - never negative evidence

T0-T1 should fit a synchronous budget. T2-T4 are policy-selected and normally asynchronous. A durable investigation can return partial evidence and later publish a new versioned decision without rewriting earlier evidence.

5. URL identity and normalization specification

Five representations - never one overloaded string

Representation	Purpose	Rules
raw_input	Forensic reproduction	Trim transport whitespace only; encrypt/store or tenant-HMAC according to retention policy.
parsed_components	Reasoning	Scheme, raw userinfo flag, ASCII hostname, Unicode display hostname, port, path, query and fragment.
comparison_url_v1	Dedup/features	Lowercase host, remove trailing dot/default port, normalize safe percent escapes and dot segments; preserve semantic path/query differences.
network_url	Dereference	HTTP(S), fragment removed, credentials rejected, approved port; regenerated only after validation.
provider_key	Connector lookup	Provider-specific canonicalization/version; do not reuse as the universal canonical URL.

Required parser order

```

bound length and Unicode bytes
-> parse exactly once with WHATWG URL
-> require http: or https:
-> reject username/password and control characters
-> normalize hostname through IDNA
-> resolve PSL public suffix + registered domain
-> build raw/display/comparison/network forms
-> emit quality and structural evidence

```

Canonicalization rules

- Never call `decodeURIComponent` on a value merely because it contains percent signs.
- Never recursively decode the entire URL. Decode only a feature-specific bounded copy, at most once, with exception-safe handling.
- Preserve both ASCII A-label and Unicode U-label hostnames; use UTS #39 skeletons only for comparison, not display.
- Use the Public Suffix List for eTLD+1, including selected private suffix behavior as an explicit versioned setting.

- Keep the fragment in the raw artifact but exclude it from network requests and most reputation lookups.
- Treat multiple extracted URLs as separate child artifacts. Never silently analyze only the first URL.

Initial input limits

Limit	Initial value	Failure
Direct URL	4,096 UTF-8 bytes	URL_TOO_LONG
URLs per investigation	20	TOO_MANY_URLS
Hostname	Protocol/library valid maximum	HOST_INVALID
Redirect parameter decode	one bounded copy, 4 KiB	ENCODING_UNSUPPORTED evidence
Parser time	25 ms p99 budget	PARSER_BUDGET_EXCEEDED

6. Static evidence and feature contract

Feature families

Family	Examples	Implementation note
Identity	PSL domain, subdomain depth, IDN scripts, UTS #39 skeleton	Compare against a versioned brand/domain registry; no static brand array in code.
Structure	lengths, delimiters, entropy, IP literal, userinfo, port	Persist feature_version and raw component lengths.
Encoding	percent escapes, double-encoding hints, bidi/control characters	Evidence only; bounded single-decode view.
Path/query	credential/payment terms, redirect keys, file extensions	Locale-aware dictionaries; separate URL text from user-supplied context.
Similarity	edit distance, keyboard proximity, homoglyph skeleton, token reorder	Generate candidates only against protected brands relevant to tenant/policy.
Infrastructure hints	shortener, free hosting, dynamic DNS	Registry-backed and time-versioned; do not hard-code permanent guilt.

Evidence, not a score shortcut

Each signal emits a reason code, value, feature version and applicability. The static feature model consumes a vector, but the individual observations remain available for explanations and regression analysis.

Reason code	Observation
URL_IDN_MIXED_SCRIPT	Unicode hostname contains risky mixed scripts under the declared UTS #39 version.
URL_BRAND_SKELETON_MATCH	Host skeleton matches a protected brand while registered domain differs.
URL_REGISTERED_DOMAIN_MISMATCH	Claimed/expected identity differs from PSL-aware destination identity.
URL_ENCODED_DESTINATION	A bounded query-value view contains another URL.
URL_SHORTENER	Registered domain belongs to a versioned shortening-service registry.
URL_CREDENTIALS_DENIED	Userinfo was present; input is unsupported and must not be dereferenced.

Bias control

A TLD, locale, country term or use of HTTP is not malicious by itself. Measure false positives by TLD, script, language, geography, tenant and hosting class. Remove any feature whose operational value depends mainly on stereotype rather than measured likelihood.

7. Hugging Face model portfolio and selection

Candidate does not mean approved

The exact Swift model is unknown from repository code. Every candidate below requires a pinned commit, Safetensors/supply-chain review, local reproduction, label-map tests, temporal/domain-grouped benchmarks, calibration and commercial license review.

Recommended portfolio

Role / proposed key	Candidate	Use	Status
Low-latency four-class URL model urlbert_malicious_v4	CrabInHoney/urlbert-tiny-v4-malicious-url-classifier	3.69M-parameter, 14.8 MB Safetensors URL classifier: benign/phishing/malware/defacement.	Primary candidate; self-host. HF provider deployment is not available on its card.
Binary phishing shadow urlbert_phishing_v4	CrabInHoney/urlbert-tiny-v4-phishing-classifier	Independent binary phishing observation; 3.69M parameters and 64-token tokenizer configuration.	Shadow only until error correlation is measured.
Multilingual shadow url_mbert_tr_v1	elftsdmr/malware-url-detect	mBERT binary model trained for Turkish malicious domains; published metrics but training data is unspecified.	Research/shadow only; do not promote from card metrics.
Static feature model url_features_gbdv_v1	Private VeriTrust LightGBM/XGBoost	PSL/IDN/structure/encoding/similarity features; structurally independent from tokenizer model.	Train and benchmark internally.
Page content model page_text_deberta_v1	microsoft/deberta-v3-small base	Fine-tune on sanitized title/visible text/form labels and relationship features.	Async custom model; base model is not a phishing classifier.
Visual brand evidence brand_siglip2_v1	google/siglip2-base-patch16-224	Optional screenshot/approved-brand embedding evidence; never a direct verdict.	Future GPU shadow; privacy and brand registry required.

Model-selection recommendation

- Use URLBERT four-class plus the private feature GBDT as the initial independent static pair.
- Keep reputation connectors independent; do not train them into an opaque label that destroys provenance.
- Add page-text/visual models only after the sandbox produces stable, sanitized artifacts.
- Do not use elftsdmr/malware-url-detect as primary: the card identifies Turkey focus and does not document its dataset.

8. Model parameter cards and registry

URLBERT four-class inference card

Parameter	Initial requirement
Repository	CrabInHoney/urlbert-tiny-v4-malicious-url-classifier; pin exact commit after review.
Task	text-classification on canonical model input; return every class probability.
Label map	LABEL_0=benign; LABEL_1=defacement; LABEL_2=malware; LABEL_3=phishing - verify against pinned config/golden fixtures.
Tokenizer	Pinned repository tokenizer; max_length=64, truncation=right, padding=max_length.
Batching	Initial CPU batch 64-128 with bounded queue delay; benchmark p50/p95/p99.
Runtime	Self-hosted Transformers/ONNX Runtime; optional INT8 only after numerical and slice equivalence.
Output	raw class probabilities + model revision + tokenizer/preprocessing/calibration versions.
Failure	Unknown/missing/non-finite/duplicate labels => MODEL_SCHEMA_FAILED.

Feature GBDT inference card

Parameter	Initial requirement
Input	Versioned dense/sparse feature vector; missingness flags retained.
Output	Four-class logits/probabilities or binary threat probability; declare exact semantics.
Runtime	Native model server or ONNX/Treelite; no arbitrary pickle loading in production.
Latency	Target <10 ms p95 per URL on a warmed CPU worker, validated under load.
Explanation	Top feature contributions are analyst-only context, not causal claims.

Registry fields - required before a model call

Field	Requirement
model_key / task	Stable internal key and exact scientific task.
repo / revision / artifact hash	Exact weights, config, tokenizer and code provenance.
input_contract	Raw vs comparison URL, max bytes/tokens and normalization version.
output_label_map	Explicit one-to-one mapping; reject unknown or duplicate semantic labels.
feature/tokenizer version	Immutable feature dictionary or tokenizer files.
calibration / thresholds	Fit artifact, population, metrics, validity dates and abstention zone.
benchmark	Dataset manifest, time range, slice metrics, robustness and approval.
deployment	disabled shadow canary production rolled_back and predecessor.

Registry ordering

Resolve and validate the registry entry before preparing model input or making the provider request. Persistence must record the same selected version, not look up whichever version happens to be active afterward.

9. Live intelligence and enrichment architecture

Connector portfolio

Source	Evidence	Operational rule
Google Web Risk	Known malicious URL/threat type and lookup timestamp.	Commercial product path; start with Lookup API, consider Update API for lower latency after scale data.
VirusTotal	URL analysis/reputation and engine observations.	Optional licensed connector; submit only under approved privacy/terms policy.
URLhaus	Known malware-distribution URL and dataset metadata.	Commercial/fair-use terms require review; no-match is not benign.
PhishTank	Verified phishing URL, target and verification time.	Use registered application key, descriptive user-agent and feed/version provenance.
DNS	A/AAAA/CNAME/NS/MX answers, TTL, DNSSEC availability/errors.	Capture all answers and resolver identity; enforce special-use IP policy.
RDAP	Registration events, registrar/RIR and response quality.	Use IANA bootstrap and RFC 9082/9083; missing/redacted data is explicit.
TLS	Certificate chain, SANs, issuer, validity and handshake errors.	Metadata only; a valid certificate is not evidence of benignness.
HTTP	Status, headers, content type/length, redirect chain.	Bound bytes/time; avoid sending credentials/cookies; default GET only when policy permits.

Connector evidence envelope

```
{
  "source": {"adapter": "web_risk.v1", "provider": "google", "version": "lookup-v1"},
  "observation": {"status": "NO_MATCH", "threat_types": []},
  "quality": {"status": "QUALIFIED", "fresh_until": "timestamp"},
  "observed_at": "timestamp",
  "request_key_hmac": "tenant-scoped",
  "reason_codes": ["REPUTATION_NO_MATCH"]
}
```

Freshness and caching

- Cache by provider-specific canonical key, tenant/privacy policy and response class.
- Positive matches use provider validity/TTL and may require faster refresh than negative lookups.
- Store observed_at, retrieved_at, expires_at and connector dataset/version token when available.
- A stale result becomes STALE evidence; it is never silently reused as current.

10. SSRF-resistant dereference boundary



Mandatory controls

- Dedicated worker identity with no application, database-admin, cloud metadata or model-build secrets.
- Egress firewall denies private, loopback, link-local, multicast, unspecified, reserved and metadata-service destinations for IPv4 and IPv6.
- Resolve A and AAAA; reject the request if any selected destination is disallowed. Do not prefer a safe answer while ignoring an unsafe answer.
- Connect only to the approved resolved address while preserving the validated hostname for HTTP Host and TLS SNI.
- Repeat URL parsing, DNS resolution and IP classification for every redirect hop.
- Disable environment proxy inheritance and internal DNS search suffixes.
- Allow ports 80 and 443 initially; other ports require an explicit per-tenant connector policy.

- No client cookies, bearer tokens, referer, form submission, upload or authenticated session.

Initial network budgets

Budget	Initial value	On breach
DNS	1.5 s per lookup, 3 s total	NETWORK_DNS_TIMEOUT
Redirects	5 hops	REDIRECT_LIMIT
Connect / total HTTP	2 s / 8 s	NETWORK_TIMEOUT
Response body	2 MiB static collector	RESPONSE_TOO_LARGE
Concurrent sockets	4 per job	NETWORK_BUDGET_EXCEEDED
Content encodings	gzip/br with 10 MiB decoded cap	DECOMPRESSION_LIMIT

Defense in depth

Application validation is not enough. The worker network namespace/VPC must independently prevent access to internal ranges and cloud metadata. Treat DNS rebinding and redirect-to-private-IP as security events.

11. Redirect, DNS and registration evidence

Redirect artifact graph

```
Artifact(url_0) --redirects_to[301]--> Artifact(url_1)
Artifact(url_1) --redirects_to[302]--> Artifact(url_2)
Entity(domain_0) --resolved_to[ttl, resolver]--> Entity(ip_0)
Evidence(reputation_1) --observed_on--> Artifact(url_1)
```

- Create one immutable URL artifact per hop. Preserve status code, location value, resolution set and observed time.
- Emit cross-domain, shortener-to-destination, HTTPS-to-HTTP and redirect-loop evidence separately.
- Do not collapse the chain to the final URL before reputation and identity checks; attackers exploit intermediate trusted domains.

DNS evidence

Observation	Store	Interpretation boundary
A/AAAA	All answers, TTL, resolver, DNSSEC metadata	Safety classification happens before connection.
CNAME	Complete bounded chain	Domain change is evidence, not automatically malicious.
NXDOMAIN/SERVFAIL	RCODE and timing	Failure/no resolution is not benign.
Fast flux	Historical answer churn when licensed data exists	Requires time-series evidence; not inferred from one lookup.

RDAP and TLS evidence

- Record registration event dates as nullable observations; never fabricate a domain age from missing/redacted data.
- Use clock-safe age calculations and retain RDAP server/bootstrap versions.
- Record certificate names, issuer, validity and chain result. Free/automated certificates are not malicious evidence.

12. Browser sandbox specification

Isolation profile

Control	Initial production setting
Runtime	Ephemeral Linux workload; non-root browser user; Chromium sandbox + seccomp; read-only root filesystem.
Network	Same validated egress proxy as static collector; every request/redirect revalidated; no internal routes.
Secrets	No application credentials; one scoped job token redeemable only for result upload.
Browser state	Fresh context; no cookies/storage; downloads, clipboard, camera, microphone, geolocation and notifications denied.
Execution	10 s page budget, 150 requests, 20 MiB network bytes, 2 MiB sanitized DOM, 5 MiB screenshot.
Artifacts	Sanitized metadata by default; screenshot/DOM retained only under explicit policy and short TTL.
Termination	Kill entire workload on limit/security violation; upload signed evidence manifest afterward.

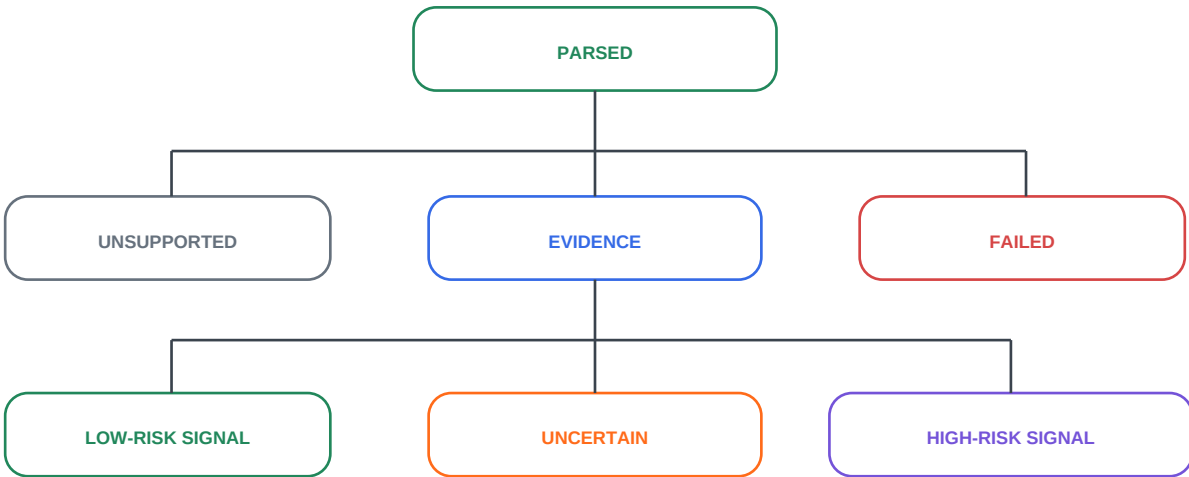
Browser evidence taxonomy

Family	Examples
Credential collection	Password/OTP/card fields, form actions, cross-origin submissions, hidden inputs.
Brand relationship	Page title/logo/text claim vs registered destination domain.
Navigation	Client-side redirects, popups, history replacement, download attempts.
Network	Third-party requests, websocket endpoints, blocked destinations, script origins.
Degradation	JS error, bot challenge, consent wall, region block, timeout, browser crash.

Playwright warning

Official Playwright documentation says its stock Docker image is not recommended as-is for visiting untrusted sites. Build a hardened image, run a non-root user with Chromium sandbox/seccomp, and add network isolation; do not copy a test-container command into production.

13. Evidence states, sufficiency and abstention



Link evidence verdicts

State	Meaning
LOW_RISK_SIGNAL	Qualified evidence leans low-risk within its scope; not a guarantee of safety.
HIGH_RISK_SIGNAL	Qualified evidence supports phishing/malware/defacement or dangerous behavior.
UNCERTAIN	Weak, stale, conflicting, OOD or insufficient observations prevent a direction.
UNSUPPORTED	Input/protocol/port/identity is outside the declared capability contract.
FAILED	Parser, provider, enrichment or sandbox failed; no benign inference is allowed.

Sufficiency profiles

Profile	Minimum evidence	Use
FAST	Parser + static features + qualified model	Low-impact UI triage; may return UNCERTAIN.
STANDARD	FAST + one current reputation source + network metadata	Default asynchronous developer/Gateway path.
HIGH_IMPACT	STANDARD + browser evidence or two qualified high-specificity sources	Block/quarantine-capable policies.

- Strong disagreement lowers decision confidence and normally creates REVIEW/UNCERTAIN.
- No-match, timeout and unsupported are distinct values; never encode them as score zero.
- Specialist evidence cannot emit ALLOW or BLOCK. Gateway policy owns the action.

14. Scoring, calibration and policy boundary

Data fields that must remain separate

Field	Definition	Never call it
raw_score	Direct model logit/probability or connector-native value.	Risk or final confidence.
calibrated_probability	Empirical probability for a declared label/population/time window.	Universal truth.
quality	Applicability, freshness, parser/model/collector completeness.	Threat probability.
evidence_sufficiency	Whether required evidence families are present and qualified.	Benign probability.
correlated_risk	Gateway correlation output from relationships and evidence.	Model score.
decision_confidence	Confidence in the versioned policy action.	Model confidence.

Calibration workflow

- Freeze a temporal/domain-grouped calibration set that was not used for model or threshold selection.
- Compare temperature scaling, Platt/logistic scaling and isotonic regression; select by log loss/Brier/ECE plus slice stability.
- Calibrate per task: phishing, malware and defacement may need separate one-vs-rest transforms.
- Choose operating thresholds from explicit false-positive cost, false-negative cost and abstention/review capacity.
- Publish reliability diagrams, confusion matrices, precision-recall curves and confidence intervals.

Current scoring migration

Retire the 0.62 model + 0.38 rule weighted blend and fixed 0.45/0.75/0.90 labels as decision logic. During compatibility migration it may remain as `legacy_link_score_v1`, clearly non-probabilistic and unable to authorize a final action.

15. Canonical data and API contracts

LinkArtifact example

```
{
  "artifact_id": "uuid", "type": "url", "raw_ref": "encrypted-or-hmac",
  "comparison_url": "https://example.co.uk/a?x=1",
  "network_url": "https://example.co.uk/a?x=1",
  "hostname_ascii": "example.co.uk", "hostname_unicode": "example.co.uk",
  "public_suffix": "co.uk", "registered_domain": "example.co.uk",
  "normalization_version": "urlnorm.v1", "psl_version": "sha256:..."
}
```

LinkEvidence example

```
{
  "evidence_id": "uuid", "artifact_id": "uuid",
  "evidence_type": "url_model",
  "source": {"adapter": "urlbert.v1", "model_key": "urlbert_malicious_v4", "revision": "commit"},
  "observation": {"verdict": "UNCERTAIN", "raw_scores": {"phishing": 0.48}, "calibrated_probability": null},
  "quality": {"status": "UNQUALIFIED", "reasons": ["CALIBRATION_MISSING"]},
  "reason_codes": ["URL_MODEL_UNCALIBRATED"], "observed_at": "timestamp",
  "schema_version": "link-evidence.v1"
}
```

Recommended endpoints

Endpoint	Behavior
POST /api/v1/link-scans	Create URL artifact(s); return fast evidence or 202 durable job.
GET /api/v1/link-scans/{id}	Return status, stage progress, evidence versions and current specialist summary.
POST /api/v1/link-scans/{id}/cancel	Idempotent cancellation for pending enrichment/browser work.
GET /api/system/capabilities	Authoritative URL limits, available tiers, connectors and degraded state.
GET /api/models	Authorized operator view of registry, benchmark and rollout status.

Error taxonomy

Class	Examples	HTTP/evidence behavior
Input	URL_INVALID, SCHEME_DENIED, CREDENTIALS_DENIED	4xx + UNSUPPORTED; never enqueue.
Contract	MODEL_LABEL_UNKNOWN, SCHEMA_INVALID	FAILED + alert; no semantic guess.
Dependency	REPUTATION_TIMEOUT, RDAP_UNAVAILABLE	Explicit failed source; continue only if policy allows.
Security	PRIVATE_IP, DNS_REBINDING, REDIRECT_PRIVATE	Abort job, security evidence and alert.
Resource	BODY_LIMIT, BROWSER_TIMEOUT, REQUEST_LIMIT	DEGRADED/FAILED evidence with exact limit.

16. Data acquisition and label governance

Source portfolio

Source	Role	Controls
PhishTank	Verified phishing positives and target metadata.	Record phish ID, verification/online time, feed version and license/attribution.
URLhaus	Malware-distribution positives.	Record first/last seen and status; review commercial fair-use terms.
Google Web Risk / licensed intel	Operational labels and delayed verification.	Do not redistribute restricted responses; retain provider provenance.
Tranco	Benign/popular-domain candidate pool.	Popularity is not benignness; sample URLs and verify; pin list ID/date and upstream terms.
Customer adjudication	Highest-value in-domain feedback.	Consent, access control, retention and label-review workflow.
Synthetic mutations	Robustness only: IDN, encoding, shortener, path/query perturbations.	Never treat automatically mutated data as real-world ground truth.

Label schema

- Primary: benign, phishing, malware_delivery, defacement, other_malicious, uncertain.
- Secondary: credential theft, payment fraud, account takeover lure, drive-by/download, redirector, compromised legitimate site.
- Status/time: first_seen, last_seen, active_at_label, verification source and adjudication confidence.

Leakage controls

- Group by registered domain, campaign cluster, hosting template and near-duplicate URL skeleton before splitting.
- Temporal holdout must occur after grouping; a domain/campaign cannot appear in train and test.
- Remove feed duplicates and provider-specific artifacts that let a model memorize the data source.
- Keep a separate never-train benchmark and a rolling forward-chaining production simulation.

Benign labels are hard

An absence from blocklists is unlabeled, not benign. Build benign data from consented/curated sources, verify reachability and content, preserve collection time, and keep compromised-legitimate-site slices separate.

17. Training and fine-tuning recipes

Recipe A - URLBERT four-class

Parameter	Starting value / search range
Input	comparison URL plus declared raw-sensitive features; max_length 64 initially; compare 96/128 for long-path recall.
Learning rate	2e-5 starting point; search 1e-5, 2e-5, 3e-5, 5e-5.
Batch	Effective 128; micro-batch by hardware; gradient accumulation allowed.
Epochs	3-5 with early stopping on temporal macro-F1 and calibration.
Optimizer	AdamW, weight_decay 0.01, linear schedule, warmup 6%, gradient clip 1.0.
Loss	Cross entropy baseline; test class weights/focal loss only against slice metrics.
Seeds	At least 3; report mean, dispersion and selected checkpoint.
Precision	bf16 on supported GPU; export Safetensors and optional ONNX after parity test.

Recipe B - independent static feature GBDT

Parameter	Starting value / search range
Trees	500-1500 with early_stopping_rounds=100.
Learning rate	0.03-0.07.
Leaves/depth	num_leaves 31-127; max_depth 6-12.
Regularization	min_data_in_leaf 50-500; L1/L2 search; feature_fraction/subsample 0.7-1.0.
Missingness	Native missing values plus explicit source/applicability flags.
Objective	Multiclass or one-vs-rest; select by operational precision-recall and calibrated loss.

Recipe C - sandbox page-text model

Parameter	Starting value / search range
Base	microsoft/deberta-v3-small; custom classifier head.
Input	Sanitized title + visible text + form labels; max 256 tokens; no scripts or secrets.
Learning rate / batch	2e-5; effective batch 32; search 1e-5 to 3e-5.
Epochs	3-5; early stop on campaign/domain/time holdout.
Outputs	credential solicitation, payment lure, malware delivery, benign-like, uncertain.

Recipe D - optional visual brand evidence

- Begin with frozen SigLIP2 screenshot and approved-brand reference embeddings at 224x224.
- Fit brand-specific similarity thresholds; evaluate screenshots from unrelated brands and legitimate login providers.
- Only fine-tune an adapter after obtaining rights to screenshots/brand assets and a leakage-safe dataset.

18. Benchmark, robustness and calibration package

Required metrics

Category	Metrics
Classification	Per-class precision/recall/F1, macro-F1, PR-AUC, ROC-AUC with confidence intervals.
Calibration	Log loss, Brier score, ECE, reliability plots before/after calibration.
Operations	False positives per 10k URLs, false negatives per 10k labeled threats, abstention/review rate.
Latency	p50/p95/p99 by tier, queue delay, cache hit ratio and browser completion rate.
Freshness	Detection lead/lag from source first-seen and evidence expiry behavior.
Security	SSRF corpus pass rate, redirect/rebinding blocks and sandbox escape regression.

Mandatory slices

- New domains, old domains, compromised legitimate domains, shorteners and open redirects.
- IDNs by script, mixed-script and confusable brands; ccTLD/public/private suffixes.
- Long URLs, encoded paths/queries, IPv4/IPv6 literals, non-default ports and malformed inputs.
- Phishing vs malware vs defacement; active vs offline; first-seen age buckets.
- India-relevant brands/lures plus other geographies and languages to quantify bias.

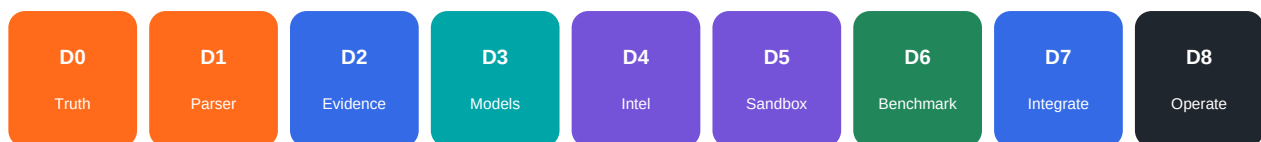
Adversarial transformations

Transformation	Invariant / expected change
Host case, default port, fragment	Comparison identity should remain stable where semantics allow.
Percent encoding and malformed percent	Parser never crashes; suspicious encoding evidence may change.
Subdomain insertion and PSL edge	Registered domain remains correct.
IDN homoglyph and bidi controls	Display remains safe; confusable/script evidence activates.
Redirect to special-use IP	Connection is blocked on every hop.
Connector timeout	Evidence fails/degrades; no safe label is created.

Promotion gates

- No regression beyond approved absolute/relative deltas on any protected slice.
- Calibration and threshold approval are versioned separately from weights.
- Shadow replay, canary, rollback target and historical reproducibility all pass.

19. Exact implementation roadmap



Do not dereference hostile URLs until the isolation and SSRF gates pass

Phase	Build	Exit gate
D0 Truth	Freeze Swift repo/commit/labels; restore migrations; define schemas/capabilities.	Golden label fixtures and clean database bootstrap pass.
D1 Parser	Total parser, credentials rejection, PSL/IDNA/UTS #39, multiple URL artifacts.	Property/fuzz corpus has zero crashes and correct eTLD+1.
D2 Evidence	LinkEvidenceAdapter, reason taxonomy, failure/freshness/sufficiency states.	All entry paths pass identical contract fixtures.
D3 Models	Pinned self-host URLBERT + feature GBDT shadow; registry before inference.	Unknown labels fail closed; reproducible inference passes.
D4 Intel	Queue, cache and Web Risk/DNS/RDAP/TLS/HTTP connectors.	Outage/freshness/backpressure tests pass.
D5 Sandbox	Hardened ephemeral browser workload and evidence manifest.	SSRF/rebinding/escape/resource-limit suite passes.
D6 Benchmark	Temporal/grouped benchmark, calibration, thresholds and robustness.	Signed benchmark package approved.
D7 Integrate	Unified API/UI/Gateway, durable progress, policy-selected tiers.	E2E partial/degraded/final journeys pass.
D8 Operate	Load tests, dashboards, drift, canary and rollback rehearsal.	Production readiness review green.

First engineering tickets

ID	Deliverable	Depends on
LNK-001	Record exact Swift model contract and golden outputs.	None
LNK-002	Replace baseDomain with pinned PSL parser.	LNK-001
LNK-003	Remove unsafe query decode; implement total parser.	LNK-002
LNK-004	Unify credential/scheme/length behavior across routes.	LNK-003
LNK-005	Create versioned LinkArtifact and LinkEvidence schemas.	LNK-001
LNK-006	Remove successful heuristic model fallback.	LNK-005
LNK-007	Resolve registry before inference and persist selected version.	LNK-005
LNK-008	Add URLBERT self-host adapter and strict label map.	LNK-007
LNK-009	Build feature extraction + GBDT shadow model.	LNK-003
LNK-010	Create async enrichment job/cache contracts.	LNK-005
LNK-011	Deploy isolated SSRF-resistant collector worker.	LNK-010
LNK-012	Add reputation, DNS, RDAP, TLS and redirect adapters.	LNK-011
LNK-013	Deploy hardened browser worker.	LNK-011
LNK-014	Build benchmark/calibration/robustness harness.	LNK-008/009/012
LNK-015	Update UI to show evidence stages and uncertainty.	LNK-005/010
LNK-016	Load, outage, canary and rollback rehearsal.	LNK-014/015

20. Test architecture

Layer	Minimum suite	Blocking failures
Unit	Normalizer, PSL, IDNA, confusables, features, label maps, calibration.	Crash, wrong domain, unknown-label acceptance, non-finite output.
Property/fuzz	Malformed percent, Unicode, IPv4/IPv6, ports, userinfo, long/query/path cases.	Unhandled exception, inconsistent canonical identity.
Contract	Every model and connector fixture including schema drift/timeouts.	Semantic guess, missing provenance/freshness.
Security	SSRF ranges, alternative IP forms, DNS rebinding, redirect-to-private, decompression bombs.	Any internal/metadata connection or fail-open.
Sandbox	Browser crash, download, popup, websocket, service worker, resource exhaustion.	Secret/network escape or unsigned result.
Integration	Queue, cache, database, idempotency, cancellation, retries and partial decisions.	Duplicate evidence, orphan job or stale decision.
Model	Frozen temporal/domain/campaign test, adversarial transforms, calibration and drift.	Protected-slice regression beyond approved delta.
E2E	Web/v1/Gateway fast, async, timeout, unsupported, failed and review journeys.	Different semantics or false-safe UI.
Load	Burst, sustained, provider throttle, queue saturation and browser concurrency.	Unbounded growth, missed deadline or tenant unfairness.

Golden parser corpus

- All current production fixtures plus RFC/WHATWG edge cases and PSL test data.
- example.co.uk and private suffix cases; uppercase/trailing-dot/default-port equivalence.
- Malformed percent, percent-encoded percent, embedded credentials and control characters.
- IPv4 alternative forms rejected by the chosen parser policy; IPv6 and mapped-address cases.
- Mixed-script IDNs and a tenant-specific protected-brand confusable set.

21. Deployment, scaling and backpressure

Recommended topology

- Vercel/API edge: validate, parse, run T0-T1 within budget, create investigation and enqueue.
- CPU model pool: warmed URLBERT/GBDT workers with dynamic batching and pinned artifacts.
- Intel worker pool: outbound-only network zone, bounded concurrent sockets and connector-specific bulkheads.
- Browser pool: isolated ephemeral workloads, low concurrency, separate queue and autoscaling policy.
- Postgres/Supabase: immutable artifacts/evidence/jobs/decisions; Redis-equivalent cache only if version/freshness correctness is preserved.

Service targets - initial, not promises

Path	Target	Scaling control
T0 parser	p99 <25 ms	Pure CPU, no network, bounded allocation.
T1 static models	p95 <100 ms warmed	Dynamic batches; queue delay cap; CPU replicas.
T2 reputation	p95 <1 s where provider permits	Cache, provider bulkhead, quota-aware shedding.
T3 network	deadline 8 s	Per-job sockets/bytes; async queue; tenant fairness.
T4 browser	deadline 20 s	Separate queue; concurrency tokens; scale from queue age.

Backpressure rules

- Admission control uses tenant quota, global capacity, job cost class and deadline.
- Never retry deterministic input/contract/security failures; exponential backoff only for qualified transient errors.
- Circuit-break failing connectors and publish explicit degraded capability state.
- Cancel queued/heavy stages when policy no longer needs them, but retain cancellation evidence.
- Autoscale on queue age and deadline risk, not CPU alone.

22. Observability, drift and feedback

Metrics

Family	Examples
Parser	reject/crash rate, PSL unknown, IDN script distribution, normalization version.
Models	latency, schema failures, class distribution, calibration/ECE, version and batch size.
Connectors	latency, quota/throttle, error/no-match/match/stale rates, cache hit and freshness.
Network	redirect depth, blocked IP class, DNS errors, bytes, timeouts and decompression limits.
Browser	queue age, launches, crashes, pages/requests/bytes, security terminations and completion.
Decisions	specialist states, Gateway actions, sufficiency, review volume and evidence mix.
Feedback	adjudicated FP/FN by model, connector, TLD, script, locale, age and campaign.

Drift policy

- Separate input/population drift, threat-campaign change, provider-feed change and model regression.
- Alert on label/schema/version changes immediately; never wait for aggregate risk movement.
- Use delayed verified/adjudicated labels for production error estimates; agreement between models is not ground truth.
- Trigger shadow re-evaluation before retraining. Drift alone does not authorize automatic model promotion.

Trace context

Every log/metric/span should carry tenant-safe request_id, investigation_id, artifact_id, job_id, adapter/version and stage. Raw URLs, query strings, screenshots, DOM and provider credentials are redacted by default.

23. Security, privacy, licensing and release governance

Security controls

- Tenant authorization on every artifact, job, evidence, decision and cached response.
- Encrypt retained URLs/DOM/screenshots; use tenant-scoped HMACs for deduplication where plaintext is unnecessary.
- Treat query strings as secret-bearing; never place raw URLs in logs, metrics labels or exception messages.
- Supply-chain scan/pin models, tokenizers, PSL data, browser images and native inference libraries.
- Sign worker result manifests and verify job identity, artifact ID, version and content hashes.
- Reproducible database migrations, clean bootstrap, upgrade and restore in CI.

Licensing and data gate

Model-code licenses do not grant rights to training data or live intelligence. Review the model, dataset, connector and redistribution terms separately. Google directs commercial malicious-URL use to Web Risk; URLhaus notes commercial/fair-use conditions; VirusTotal requires an appropriate API license; Tranco combines upstream lists with different licenses.

Definition of done

- No valid/malformed URL can crash the parser; PSL and IDN behavior is reproducible.
- No provider/model output can acquire meaning without an exact validated registry contract.
- No missing/stale/failed connector or model result becomes low-risk evidence.
- No dereference path can reach special-use/internal/metadata destinations across redirects or rebinding.
- Every result reproduces from artifact, normalization, PSL, feature, model, calibration, connector and policy versions.
- UI and exports show uncertainty, freshness and stage failures without an unexplained confidence percentage.

24. Interactive operator worksheet

Complete these fields before LNK-001/LNK-007. The exact deployed model and commercial operating context are intentionally not inferred from hidden production configuration.

Current Swift deployment

Hugging Face repository

Exact commit SHA

Scientific task

Raw labels / indices

Tokenizer + max length

Input normalization

Runtime / provider

License approval

Target operating context

Primary customers/use

Locales / geographies

False-positive budget

False-negative budget

Peak URLs / minute

Fast-path latency

Enrichment deadline

Review capacity / day

Retention requirement

Connector and sandbox approvals

Web Risk plan / region

VirusTotal license

URLhaus terms

PhishTank app key/terms

RDAP resolver policy

Worker network / region

Browser image + digest

Sandbox retention

25. Interactive implementation and release checklist

Truth and parser

- ☐ Exact Swift repository, commit, task, tokenizer, label map and license recorded
- ☐ Golden fixtures prove every provider label semantic
- ☐ Unknown/duplicate/missing/non-finite model outputs fail closed
- ☐ PSL-aware registered domain and pinned PSL version implemented
- ☐ Total single-decode URL parser passes property/fuzz corpus
- ☐ Scheme, credentials, port and size rules are identical across all routes
- ☐ Multiple extracted URLs become distinct related artifacts
- ☐ LinkArtifact/LinkEvidence schemas and runtime validators merged
- ☐ Successful local model fallback removed
- ☐ Model registry resolves exact revision before inference
- ☐ URLBERT and feature-model shadow adapters are reproducible
- ☐ Raw score, calibrated probability, quality, sufficiency and risk separated
- ☐ Temporal/domain/campaign grouped benchmark approved
- ☐ Calibration transforms and abstention thresholds approved
- ☐ Async jobs, idempotency, retry, deadline and cancellation implemented
- ☐ Connector provenance, freshness, cache and no-match semantics implemented
- ☐ Every redirect hop repeats URL, DNS and IP validation
- ☐ Special-use/internal/metadata egress is blocked and tested
- ☐ Hardened non-root browser sandbox passes escape/resource tests
- ☐ UI shows partial/degraded/uncertain/failed evidence honestly
- ☐ Provider, model, queue, network, sandbox and drift dashboards are live
- ☐ Tenant/privacy/retention/connector-license review approved
- ☐ Load/backpressure/failure-injection tests meet service targets
- ☐ Shadow, canary, rollback and historical reproduction rehearsal completed

26. Sources and primary references

- S1. VeriTrust Four Core Detection Architecture Blueprint, 9 Aug 2026 (local project PDF).
- S2. RFC 3986 - Uniform Resource Identifier: Generic Syntax. <https://www.rfc-editor.org/info/rfc3986/>
- S3. WHATWG URL Standard. <https://url.spec.whatwg.org/>
- S4. Public Suffix List official repository. <https://github.com/publicsuffix/list>
- S5. tldts package documentation. <https://www.npmjs.com/package/tldts>
- S6. Unicode UTS #39 - Unicode Security Mechanisms. <https://www.unicode.org/reports/tr39/>
- S7. OWASP Server-Side Request Forgery Prevention Cheat Sheet.
https://cheatsheetseries.owasp.org/cheatsheets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet.html
- S8. IANA IPv4 Special-Purpose Address Registry. <https://www.iana.org/assignments/iana-ipv4-special-registry/iana-ipv4-special-registry.xhtml>
- S9. IANA IPv6 Special-Purpose Address Registry. <https://www.iana.org/assignments/iana-ipv6-special-registry/iana-ipv6-special-registry.xhtml>
- S10. RFC 9082 - RDAP Query Format. <https://www.rfc-editor.org/rfc/rfc9082.html>
- S11. RFC 9083 - RDAP JSON Responses. <https://www.rfc-editor.org/rfc/rfc9083.html>
- S12. Google Cloud Web Risk - Detect malicious URLs. <https://docs.cloud.google.com/web-risk/docs/detect-malicious-urls>
- S13. Google Safe Browsing commercial-use direction. <https://developers.google.com/safe-browsing/>
- S14. VirusTotal API v3 URL documentation. <https://docs.virustotal.com/reference/url>
- S15. URLhaus Community API and usage terms notice. <https://urlhaus.abuse.ch/api/>
- S16. PhishTank developer feeds and API guidance. https://phishtank.org/developer_info.php
- S17. Tranco reproducible top-site rankings. <https://tranco-list.eu/>
- S18. Official Playwright Docker security guidance. <https://playwright.dev/docs/docker>
- S19. Hugging Face URLBERT Tiny v4 malicious URL model card. <https://huggingface.co/CrabiHoney/urlbert-tiny-v4-malicious-url-classifier>
- S20. Hugging Face URLBERT Tiny v4 phishing model card. <https://huggingface.co/CrabiHoney/urlbert-tiny-v4-phishing-classifier>
- S21. Hugging Face elftsdmr malware URL model card. <https://huggingface.co/elftsdmr/malware-url-detect>
- S22. Microsoft DeBERTa-v3-small model card. <https://huggingface.co/microsoft/deberta-v3-small>
- S23. Google SigLIP2 base 224 model card. <https://huggingface.co/google/siglip2-base-patch16-224>
- S24. NIST AI Risk Management Framework resources. <https://airc.nist.gov/airmf-resources/airmf/5-sec-core/>

Final implementation starting point

Begin with LNK-001 through LNK-007: freeze Swift semantics, restore authoritative migrations/schemas, replace baseDomain and unsafe decoding, unify route behavior, remove successful heuristic fallback and resolve the registry before inference. Do not build live dereferencing until the isolated worker and SSRF gates are ready.

END OF HANDBOOK